

State of Maine

Department of Administrative and Financial Services

Office of Information Technology

System and Communications Protection Procedures for Specific Technologies (SC-10, 15, 18, and 40)

System and Communications Protection Procedures for Specific Technologies (SC-10, 15, 18, and 40)

Table of Contents

1.0. Document Purpose 3

2.0. Scope 3

3.0. Procedure Conflict 3

4.0. Roles and Responsibilities 3

5.0. Management Commitment 3

6.0. Coordination Among Agency Entities 3

7.0. Compliance 3

8.0. Procedures 4

9.0. Document Details 6

10.0. Review 6

11.0. Records Management 6

12.0. Public Records Exceptions 7

13.0. Definitions 7

14.0. Abbreviations 8

System and Communications Protection Procedures for Specific Technologies (SC-10, 15, 18, and 40)

1.0. Document Purpose

The purpose of this document is to define the State of Maine procedures for implementing system and communications protection requirements for specific technologies that support the State's information technology environment. These procedures outline how OIT applies required safeguards to ensure the confidentiality, integrity, and availability of State information assets when using these technologies. This document corresponds to the System and Communications Protection (SC) Control Family of National Institute of Standards and Technology (NIST) Special Publication 800-53 (Rev. 5).[1]

2.0. Scope

2.1. These procedures apply to State of Maine employees and contractors (collectively referred to as personnel in this document) with access to:

2.1.1. Executive Branch Agency information assets, irrespective of location; and

2.1.2. Information assets from other State government branches that use Executive Branch-managed services.

3.0. Procedure Conflict

If these procedures conflict with any law or union contract in effect, the terms of the existing law or contract prevail.

4.0. Roles and Responsibilities

Please refer to the System and Communications Protection Policy and Procedures (SC)[2] document for further information.

5.0. Management Commitment

The State of Maine is committed to following these procedures and the policy that it supports.

6.0. Coordination Among Agency Entities

Please refer to the System and Communications Protection Policy and Procedures (SC)[3] document for further information.

7.0. Compliance

7.1. For State of Maine employees, failure to comply with this document may result in progressive discipline, up to and including dismissal.

---

[1] https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final
[2] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf
[3] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf

7.2. For State of Maine contractors and non-State of Maine personnel, failure to comply may result in the removal of the individual's ability to access and use State of Maine data and systems. Employers of contractors will be notified of any violations.

7.3. Personnel are also subject to applicable penalties for statutory requirements compliance violations. Depending on the requirement and the nature of the violation, penalties could include fines and/or criminal charges.

8.0. Procedures

The following standards apply to and represent the security controls established to meet an acceptable level of protection for the State of Maine's information assets supported by the specific technologies addressed in this document.

8.1. SC Controls, Cross References: The following controls for the System and Communications Protection Policy and Procedures (SC) are published in separate policy and procedure documents:

8.1.1. System and Communications Protection Policy and Procedures (SC);[4]

8.1.2. System and Communications Protection Procedures for Defense in Depth (SC-2, 4, 5, 20, 21, 22, 23, 28, 32, and 39);[5] and

8.1.3. System and Communications Protection Procedures for Encryption Mechanisms (SC-12, 13, and 17).[6]

8.1.4. System and Communications Protection controls applicable exclusively to Federal Tax Information (FTI), including Voice over Internet Protocol (SC-19), are addressed in IRS Publication 1075–scoped documentation and are not implemented within the general System and Communications Protection procedures.

8.2. Network Disconnect (SC-10)

8.2.1. The OIT Network Services team ensures Virtual Private Network (VPN) connections associated with a communications session are:

8.2.1.1. Terminated at the end of a session when the user disconnects.

8.2.1.2. Automatically deallocate inactive Dynamic Host Configuration Protocol (DHCP) (see Definition) leases after seven (7) days. An active Internet Protocol (IP) address may be reallocated as long as the device is in session.

[4] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SystemCommunicationsProtectionPolicy.pdf
[5] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCDefenseInDepthProcedures.pdf
[6] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/SCEncryptionMechanismsProcedures.pdf

8.2.1.3. Automatically terminated thirty (30) minutes after the computer enters sleep mode due to inactivity.

8.2.1.4. Automatically terminated after 24 hours of continuous connection.

8.2.1.5. Terminated or suspended upon issuance of an order by the OIT Chief Information Officer (CIO) or Chief Information Security Officer (CISO).

8.2.2. Following all session terminations, authentication is required for the user to reenter the SOM network.

8.3. Collaborative Computing Devices (SC-15)

8.3.1. OIT Client Technologies prohibits remote activation of collaborative computing devices (see Definitions), for example, networked whiteboards, cameras, and microphones.

8.3.2. OIT Client Technologies provides explicit indication of use to users physically present at the collaborative computing devices. Explicit indication of use includes, for example, signals to users when collaborative computing devices are activated.

8.3.3. **Physical Disconnect (SC-15(1)):** OIT Client Technologies ensures collaborative computing devices are automatically disconnected when a session ends to ensure participant disconnection.

8.3.4. OIT Client Technologies disables remote access to collaborative computing devices from information systems or information system components through VPN Deny and Active Directory to prevent, for example, eavesdropping on conversations.

8.3.5. **Explicitly Indicate Current Participants (SC-15(4)):** Signaling local users is done to show those who are physically present at their cameras when collaborative computing devices are in use.

8.4. Mobile Code (SC-18)

8.4.1. OIT Security, as well as all the Information Asset Owners, define and establish usage, restrictions, and guidance for mobile code technologies (see Definitions). They authorize, monitor, and control mobile code technologies within the information system through OIT's Change Management Policy and Procedures.[7] The acquisition, development, and use of mobile code must comply with all regulatory requirements applicable to the data handled by the user.

[7] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf

8.4.2. The most current state-of-the-art mobile code technologies are derived principally from two sources: the product vendors and other Industry Partners (see Definitions).

8.4.3. When mobile code technologies are identified as either deprecated and/or vulnerable, these products are processed through the procedures outlined in OIT's Change Management Policy and Procedures[8] for divestment.

8.5. **Wireless Link Protection (SC-40)**

8.5.1. OIT Network Security protects external and internal wireless links from signal parameter attacks through the following methods:

8.5.2. A dedicated wireless service set identifier (SSID) (SOM AIRE) is used for public anonymous Internet connectivity within State of Maine office locations.

8.5.3. All other wireless SSIDs that provide connectivity to the private or internal State of Maine Network require dual authentication, including Active Directory account authentication and device certificate authentication.

9.0. Document Details

9.1. Initial Issue Date: April 28, 2023

9.2. Latest Revision Date: January 16, 2026

9.3. Point of Contact: PolicyTeam.OIT@Maine.Gov

9.4. Approved By: Chief Information Officer, OIT

9.5. Legal Citation: Title 5, Chapter 163: Office of Information Technology[9]

9.6. Waiver Process: Waiver Policy[10]

9.7. Distribution: Internet[11]

10.0. Review

This document will be reviewed triennially, and when substantive changes are made to Policies, Procedures, or other authoritative regulations affecting this document.

11.0. Records Management

OIT security policies, plans, and procedures fall under the *Major Administrative Policies and Procedures* and *Internal Control Policies and Directives* records management categories. They will be retained for a minimum of six years after

[8] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/ChangeManagementPolicy.pdf
[9] https://legislature.maine.gov/statutes/5/title5ch163sec0.html
[10] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/waiver.pdf
[11] https://www.maine.gov/oit/policies-standards

withdrawal or replacement and then destroyed in accordance with guidance[12] provided by Maine State Archives. Retention of these documents will be subject to any future State Archives General Schedule revisions that cover these categories.

12.0. Public Records Exceptions

Under the Maine Freedom of Access Act (FOAA),[13] certain public records exceptions may limit disclosure of agency records related to information technology infrastructure and systems, as well as security plans, procedures, or risk assessments. Information contained in these records may be disclosed to the Maine State Legislature or, in the case of a political or administrative subdivision, to municipal officials or board members under conditions that protect the information from further disclosure. Any aggrieved person seeking relief for an alleged violation of the FOAA may bring suit in any Superior Court in the State.

13.0. Definitions

13.1. Asymmetric Key Cryptography: A cryptographic system where users have a private key that is kept secret and used to generate a public key (which is freely provided to others). Users can digitally sign data with their private key, and the resulting signature can be verified by anyone using the corresponding public key. Also known as public-key cryptography. Source: NIST.[14]

13.2. Certificate Authority: A trusted entity that issues and revokes public key certificates. Source: NIST.[15]

13.3. External-facing Applications: Applications that are open to the internet and provide content to public users, internal employees, and business partners.

13.4. Lookout: A data protection and cloud security platform.

13.5. Media Player (MP): Software that "plays" audio, video, or animation files on a computer. Windows Media Player is the default player from Microsoft, but iTunes, RealPlayer, and other software are also widely used. iTunes and QuickTime Player are the default products for Mac devices.

13.6. Microsoft Intune: A cloud-based service that focuses on mobile device management and mobile application management for mobile phones, tablets, and laptops (part of Microsoft Endpoint Manager).

13.7. Principle of Least Privilege: A security principle where users are assigned the minimal access necessary to perform their job responsibilities. Access is granted for the shortest duration possible.

[12] https://www.maine.gov/sos/sites/maine.gov.sos/files/content/assets/GS1Administrative.pdf
[13] https://legislature.maine.gov/statutes/1/title1sec402.html
[14] https://csrc.nist.gov/glossary/term/asymmetric_key_cryptography
[15] https://csrc.nist.gov/glossary/term/certificate_authority

13.8. Private Key: A cryptographic key, used with a public key cryptographic algorithm, that is uniquely associated with an entity and is not made public. Source: NIST.[16]

13.9. Public Key Infrastructure (PKI): The architecture, organization, techniques, practices, and procedures that collectively support the implementation and operation of a certificate-based public key cryptographic system. Framework established to issue, maintain, and revoke public key certificates. Source: NIST.[17]

13.10. Traffic Light Protocol (TLP): A standardized information-sharing protocol used to indicate the sensitivity of information and the extent to which it may be shared. TLP markings are used to guide the handling, dissemination, and protection of information and may be applied to a wide range of information types, including but not limited to sensitive or restricted data. Within the State of Maine, the Federal Homeland Security Traffic Light Protocol is used by OIT to support the classification of Personally Identifiable Information (PII) impact level. See the Data Classification Policy.[18]

13.11. Trust Anchor: An authoritative public key or certificate authority that is explicitly trusted to establish and validate trust relationships within a public key infrastructure. Trust anchors are typically root certificate authority certificates and are used to validate certificate chains within trust stores.

13.12. Trust Store: A list of root, intermediate, and user certificates that are trusted by the operating system or application.

13.13. Unencrypted Transmission: A communication method that does not meet encryption requirements as outlined in the Transmission of Sensitive Information Standard. For example, confidential or sensitive data may be intercepted by a malicious user if plaintext data is transmitted across an unencrypted network, allowing them to gain unauthorized access. This method can jeopardize the confidentiality of the sensitive data.

14.0. Abbreviations

14.1. AES: Advanced Encryption Standard

14.2. CA: Certificate Authority

14.3. DVD: Digital Video Disks

14.4. FIPS: Federal Information Processing Standards

14.5. FOAA: [Maine] Freedom of Access Act

14.6. MP: Media Players (MP3 and MP4)

14.7. NIST: National Institute of Standards and Technology

14.8. NSA: National Security Agency

[16] https://csrc.nist.gov/glossary/term/private_key
[17] https://csrc.nist.gov/glossary/term/pki
[18] https://www.maine.gov/oit/sites/maine.gov.oit/files/inline-files/DataClassificationPolicy.pdf

14.9.	OIT:	Office of Information Technology
14.10.	PII:	Personally Identifiable Information
14.11.	PKI:	Public Key Infrastructure
14.12.	SC:	System and Communications Protection Policy and Procedures
14.13.	SD:	Secure Digital Cards
14.14.	SOM:	State of Maine
14.15.	TLP:	Traffic Light Protocol